

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to define the cloud reference architecture and explain its purpose as a conceptual framework for cloud security analysis.
- By the end of this lecture, you will be able to identify the four primary cloud computing activity roles — cloud service user, cloud service provider, cloud service partner, and regulator — and articulate the accountability implications of each.
- By the end of this lecture, you will be able to distinguish between application, platform, and infrastructure capability types and map them to the corresponding service categories.
- By the end of this lecture, you will be able to explain the role of APIs as architectural interfaces and describe the security controls required to protect them.
- By the end of this lecture, you will be able to apply the reference architecture as a structured assessment lens to identify security gaps and accountability boundaries in any cloud environment.
- By the end of this lecture, you will be able to articulate the distinction between cloud computing activities and cloud service capabilities, and explain why conflating them produces incomplete security assessments.

Introduction

The cloud reference architecture is the shared grammar of cloud security. It is a conceptual framework — developed primarily by NIST, with related contributions from the Cloud Security Alliance (CSA) and ISO — that describes how cloud computing is organized: what roles exist, what activities those roles perform, and what kinds of capabilities each layer of the cloud provides. Unlike product documentation or a vendor whitepaper, the reference architecture applies universally. Whether you are assessing an AWS deployment, an Azure environment, or a private cloud built on OpenStack, the same roles, activity categories, and capability types apply. That universality is precisely what makes it valuable.

For cloud security practitioners, the reference architecture serves two functions simultaneously. First, it is a communication tool. When a security professional says a control applies at the platform capability layer, every other professional in the conversation understands immediately what sits above it and below it. Second, it is an analytical tool. When you are brought into a new engagement, walking through the reference architecture systematically — who are the users, who is the provider, are brokers or auditors involved, what capability types are in use — produces a structured picture of the environment in minutes. The architecture does not tell you what the risks are, but it tells you exactly where to look for them.

The CCSP exam draws on NIST, CSA, and ISO frameworks, and the reference architecture underpins all of them. When you encounter a CSA security guidance document or a NIST cloud security publication, the roles they describe, the threat actors they identify, and the controls they recommend all assume this architectural context.

Building a solid mental model of the reference architecture first makes every other cloud security framework significantly easier to understand and apply.

Core Concepts Explained

Cloud Computing Activities and Roles

Definition: Cloud computing activities describe what different participants actually do within a cloud environment. The four primary roles are the cloud service user, the cloud service provider (CSP), the cloud service partner (which includes brokers and auditors), and the regulator.

Business relevance: Mapping roles to accountability is the foundation of cloud governance. When a security incident occurs, the question 'whose responsibility was this?' can only be answered clearly if the roles involved are properly understood and contractually defined. Ambiguity in role mapping is a leading cause of unresolved liability after cloud incidents.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you use the activity role framework to structure accountability in contracts, incident response plans, and security assessments. Before any engagement, you should be able to name every role present in the environment and articulate their specific obligations.

Real-world example: In 2019, Capital One experienced a breach in which a misconfigured AWS Web Application Firewall allowed an attacker to exfiltrate over 100 million customer records from an S3 storage bucket. The post-incident analysis turned precisely on role accountability: AWS (the CSP) was responsible for the security of the underlying infrastructure and the WAF product itself. Capital One (the cloud service user) was responsible for the configuration of that WAF and for the access policies governing its S3 buckets. A third-party security auditor who had reviewed the environment months earlier had failed to flag the misconfiguration — raising questions about the cloud service partner (auditor) role and what their assessment scope actually covered. The reference architecture's role framework made the accountability analysis tractable. Without it, the question of who failed and who was liable would have been far harder to structure.

Risks or limitations: When roles overlap or go undefined, security controls fall into gaps between them. The best practice is to document role assignments in the cloud governance framework before deployment and to revisit them whenever the service model, provider, or business context changes.

Cloud Service Capabilities: Application, Platform, and Infrastructure

Definition: The reference architecture organises what cloud services deliver into three capability types: application capability (finished software accessed by end users), platform capability (development environments, runtimes, and managed services for building applications), and infrastructure capability (raw compute, storage, and networking).

Business relevance: The capability type in use determines the division of security responsibility between the CSP and the customer. Misidentifying the capability type — or failing to identify it at all — is one of the most common causes of the 'responsibility gap' in which customers assume the provider handles controls that are actually theirs to manage.

Cloud Security Practitioner relevance: Cloud Security Practitioners use capability type classification to scope security assessments, set contractual expectations with providers, and design the appropriate control layer for each environment. Capability type is the first classification to establish in any cloud security engagement.

Real-world example: Amazon Web Services launched in 2006 with infrastructure capability offerings: Elastic Compute Cloud (EC2) for compute and Simple Storage Service (S3) for storage. Over the following decade, AWS

layered platform capabilities on top — Relational Database Service (RDS), Lambda serverless compute, Elastic Kubernetes Service — and then application capabilities such as Amazon WorkMail and Amazon Connect. A security practitioner assessing a single enterprise's AWS environment might encounter all three capability types simultaneously: EC2 instances (infrastructure), a Lambda-based microservices layer (platform), and Amazon Connect for a customer service centre (application). The security controls required, and the party responsible for applying them, differ materially across all three. Using the capability type framework prevents the assessment from treating everything as the same kind of risk.

Risks or limitations: Practitioners who treat capability types interchangeably often over-apply infrastructure security controls in SaaS environments (wasting effort) and under-apply application security controls in IaaS environments (creating exposure). The best practice is to classify capability type explicitly for every service in scope before designing the control set.

APIs as Architectural Interfaces and Security Concerns

Definition: Application Programming Interfaces (APIs) are the structured interfaces through which cloud components communicate. Every layer of the cloud reference architecture — infrastructure, platform, and application — exposes and consumes APIs, making API security a cross-cutting concern throughout the entire architecture.

Business relevance: APIs are the attack surface of the cloud. Unprotected or poorly secured APIs allow attackers to enumerate resources, escalate privileges, exfiltrate data, and disrupt services without ever touching the underlying infrastructure. The OWASP API Security Top 10 documents attack patterns that are routinely exploited against cloud-based APIs.

Cloud Security Practitioner relevance: Cloud Security Practitioners are responsible for ensuring that every API in scope is authenticated, authorised, encrypted in transit, rate-limited, and logged. This applies to APIs consumed by the organisation (provider APIs), APIs exposed by the organisation (customer-facing APIs), and internal APIs between services.

Real-world example: In 2021, Twitch suffered a source code leak partly attributed to misconfigured API access controls on internal systems. The reference architecture lens makes this analysable: Twitch was using cloud infrastructure and platform capabilities from AWS, and the APIs connecting internal services had insufficient access controls — specifically, overly permissive IAM policies on API endpoints. A security practitioner applying the reference architecture would, in a standard engagement, review API gateway configurations, verify that authentication is required for every API call, confirm that authorisation is scoped to least-privilege, check that TLS 1.2 or higher is enforced on all API traffic, and verify that API call logs are being captured and monitored. Each of these is a direct security concern flowing from the reference architecture's treatment of APIs as the defining interfaces between architectural layers.

Risks or limitations: The most critical API security failures are: missing authentication (unauthenticated endpoints), broken object-level authorisation (one user can access another user's data by changing an ID parameter), and excessive data exposure (APIs returning more data than the consuming application displays). The best practice to prevent all three is to apply authentication and least-privilege authorisation at the API gateway level, not just within individual services.

Cloud Service Brokerage and Its Security Implications

Definition: A cloud service broker is a cloud computing partner role that acts as an intermediary between cloud service users and cloud service providers. Brokers aggregate, integrate, or customise cloud services — potentially combining offerings from multiple CSPs — to create unified solutions for customers.

Business relevance: Brokerage adds a layer of abstraction that can simplify procurement and service management for customers. It also introduces additional trust relationships that must be assessed. The broker's own security posture, its contractual relationships with underlying providers, and its data handling practices all become relevant to the overall security of the customer's environment.

Cloud Security Practitioner relevance: When assessing any cloud environment that involves a broker, Cloud Security Practitioners must extend their assessment scope to include the broker's security controls, their subprocessor agreements with underlying CSPs, and the contractual provisions governing what happens to customer data if the broker relationship changes or the broker ceases trading.

Real-world example: A professional services firm engaged a cloud service broker to manage a hybrid environment combining Microsoft Azure for office productivity (application capability), an AWS PaaS environment for application development (platform capability), and a managed security monitoring service from a specialist vendor. The broker provided a single dashboard and billing interface. When a third-party security assessment was conducted, the assessor using the reference architecture identified that the broker had access to credentials across all three environments for management purposes — a significant trust relationship with material security implications. The assessment required the broker to demonstrate that their own access was controlled through privileged access management, that their staff were background-checked, and that their operations were covered by a SOC 2 Type II report. Without the reference architecture's explicit identification of the broker role, this trust relationship might have been overlooked.

Risks or limitations: The primary risk of brokerage is concentrating access and trust in an intermediary whose own security posture may not be subject to the same scrutiny as the primary CSP. The best practice is to conduct a security assessment of any broker equivalent to a full vendor assessment, including reviewing their own supply chain of underlying cloud providers.

Cloud Service Auditors and Independent Assurance

Definition: A cloud service auditor independently assesses and reports on the security, performance, or compliance of a cloud service. Auditors provide external assurance that organisations cannot easily obtain through self-assessment, because most cloud providers restrict direct customer access to their underlying infrastructure.

Business relevance: Independent audit reports — including SOC 1, SOC 2 Type II, and ISO 27001 certifications — are the primary mechanism through which cloud customers obtain assurance about provider security controls. Understanding what these reports cover, their scope limitations, and how to interpret them is a core cloud governance skill.

Cloud Security Practitioner relevance: Cloud Security Practitioners are responsible for identifying which audit reports are relevant to a given service, requesting current copies, reviewing their scope to confirm that the controls relevant to the customer's use case are covered, and flagging scope gaps for management as residual risk.

Real-world example: A global pharmaceutical company evaluating AWS for storing clinical trial data needed to satisfy both FDA 21 CFR Part 11 and EU GMP Annex 11 requirements for electronic records. The company's cloud security practitioner obtained AWS's SOC 2 Type II report and its ISO 27001 certificate. Critically, the practitioner reviewed the specific scope of each — the SOC 2 report covered a defined set of AWS services, and the clinical trial data environment needed to use only those services. Where the trial workflows required additional AWS services not within the SOC 2 scope, the practitioner documented this as a residual risk requiring compensating controls. This is the reference architecture's auditor role in direct practice: the auditor's reports constrain what you can rely on, and the practitioner must map the report scope to the actual service capability in use.

Risks or limitations: The most common assurance failure is accepting a compliance certification without verifying that its scope covers the specific services and controls in use. A SOC 2 Type II report for a cloud provider's infrastructure services does not automatically provide assurance for that provider's newer platform services that were not in scope when the audit was conducted. The best practice is to review scope sections carefully and seek supplementary assurance for out-of-scope services.

Practical Applications

The following scenarios illustrate how Cloud Security Practitioners apply the cloud reference architecture in real engagements to structure assessments, resolve accountability questions, and design appropriate security controls.

Structuring a Cloud Security Assessment Using the Reference Architecture

A Cloud Security Practitioner is engaged to assess the cloud environment of a retail organisation that has migrated its e-commerce platform to a major public cloud provider. The practitioner begins not by running scanning tools but by walking through the reference architecture systematically: Who is the cloud service user? In this case, the retailer's development and operations teams. Who is the CSP? The public cloud provider. Are there cloud service partners involved? Yes — a managed security services provider (MSSP) is operating as a broker, aggregating security monitoring services across multiple cloud regions. Are there auditors? The CSP holds a SOC 2 Type II certification; the MSSP does not. What capability types are in use? Infrastructure (virtual machines and load balancers), platform (managed database and container orchestration), and application (a SaaS analytics tool). With this picture established, the practitioner identifies immediately that the MSSP's lack of independent audit coverage is a governance gap, and that the IaaS virtual machines require a different control assessment approach than the PaaS container environment. The reference architecture produced a structured assessment scope in under an hour, before a single technical test was run.

Resolving Accountability After a Cloud Security Incident

A financial services organisation experiences a data exposure event in which customer account data stored in a cloud object storage bucket is discovered to be publicly accessible. The cloud security team is asked to determine accountability. Applying the reference architecture, the practitioner maps the situation: the storage service is an infrastructure capability — the CSP manages the underlying hardware and the storage service itself, but the customer is responsible for configuring access policies on the bucket. The access policy that allowed public access was set by a member of the customer's DevOps team, not by the CSP. The cloud service partner role in this environment included a compliance auditor who had reviewed the environment two months earlier but whose scope explicitly excluded individual bucket-level access policy review. Accountability is therefore clear: the customer's DevOps team configured the bucket incorrectly, and the auditor's scope did not cover this control. The practitioner uses this finding to recommend that future audit scopes include explicit coverage of storage access policy review and that automated policy compliance checks (using the CSP's configuration management service) be implemented to catch public-access misconfigurations before they reach production.

Evaluating a Cloud Service Broker Relationship for a Regulated Customer

A healthcare organisation is considering using a cloud service broker to manage a multi-cloud environment that combines infrastructure from two CSPs and a SaaS clinical records platform. The Cloud Security Practitioner is asked to assess the broker relationship before contract execution. Using the reference architecture, the practitioner identifies that the broker will have privileged access to identity and access management configurations across all three environments — a significant trust concentration. The practitioner designs a

vendor assessment that covers the broker's own SOC 2 report scope, their subprocessor agreements with each underlying CSP, their data handling and retention policies, their incident response commitments, and their financial stability (because broker cessation would disrupt access management across the entire environment). The practitioner also recommends contractual provisions requiring the broker to notify the healthcare organisation within 24 hours of any security event affecting the managed environments, and to provide an exit plan that allows the organisation to take over direct management of the CSP relationships within 30 days if needed. The reference architecture's explicit treatment of the cloud service partner role provided the framework for identifying every dimension of this assessment.

Best Practices

- **Map the reference architecture before running any technical test.** In every new cloud engagement, document the cloud activity roles present — user, provider, partner, regulator — before beginning technical assessment. This mapping takes less than an hour and prevents both over-scoping (assessing controls that belong to another party) and under-scoping (missing controls in the responsibility gap). Create a simple table: role, organisation name, contractual obligations, and audit coverage.
- **Classify capability types explicitly for every service in scope.** For each cloud service in a given environment, assign a capability type classification: application, platform, or infrastructure. Document this in the assessment record. The classification determines the shared responsibility boundary, which in turn determines which security controls are yours to verify and which belong to the provider. Never treat all cloud services as the same category.
- **Treat every API as a potential attack surface requiring explicit security controls.** For every API in scope — whether consumed from a CSP, exposed to customers, or used for internal service-to-service communication — verify that authentication is required, authorisation follows least privilege, all traffic is encrypted in transit (TLS 1.2 minimum), rate limiting is configured, and access is logged. Apply the OWASP API Security Top 10 as a baseline checklist for any application or platform capability layer.
- **Extend vendor assessment scope to include all cloud service partners.** Any cloud service partner — broker, aggregator, MSSP, or integration provider — who has access to the environment should be subject to a vendor security assessment equivalent in rigour to the assessment of a primary CSP. At minimum, obtain and review their most recent SOC 2 Type II report, confirm their subprocessor agreements are documented, and establish contractual security requirements covering incident notification timelines and exit provisions.
- **Use independent audit reports to verify provider security, but always check scope.** Request the most current SOC 2 Type II report and ISO 27001 certificate for any cloud provider in scope. Before relying on these for assurance, review the scope section carefully: confirm that the specific services your organisation uses are included, that the audit period is current (not expired), and that the control objectives covered are relevant to your security requirements. Document any services or controls that fall outside the report scope as residual risks requiring compensating controls.

Common Mistakes and Misconceptions

Misconception: Treating the cloud reference architecture as theoretical background rather than an active analytical tool.

Correct approach: Apply the reference architecture as the first step of every cloud security engagement. Map roles, capability types, and interfaces before beginning any technical assessment. This practice prevents scope errors and produces a defensible, structured assessment record.

Misconception: Conflating cloud computing activities (what participants do) with cloud service capabilities (what services provide), resulting in assessments that are either too operationally focused or too technically focused.

Correct approach: Maintain explicit separation between the two dimensions in every assessment. Activities map to accountability (who is responsible for what). Capabilities map to the technical scope of controls (which security measures apply at which layer). Both dimensions must be assessed for a complete security picture.

Misconception: Accepting a cloud provider's compliance certification at face value without verifying that its scope covers the specific services and controls in use.

Correct approach: Review the scope section of every SOC 2 report and ISO certification before relying on it for assurance. Identify any services used by the organisation that fall outside the audit scope and document these as residual risks requiring compensating controls or additional assurance mechanisms.

Misconception: Overlooking the security implications of cloud service broker relationships, treating brokers as pass-through intermediaries with no independent security risk.

Correct approach: Conduct a full vendor security assessment of any cloud service broker, focusing on their own access controls, audit coverage, subprocessor relationships, incident response commitments, and contractual exit provisions. Broker access concentration is a material security risk that must be explicitly managed.

checklist: Cloud Reference Architecture Assessment Checklist

Use this checklist at the start of every cloud security engagement to establish the reference architecture baseline before beginning technical assessment. Complete all items before proceeding to technical testing.

- ☐ Identify and document all cloud service users in scope (human users and automated systems)
- ☐ Identify and document the cloud service provider(s) and the services they deliver
- ☐ Identify all cloud service partners: brokers, aggregators, MSSPs, auditors, and integration providers
- ☐ Identify the regulatory bodies or compliance frameworks that govern the environment
- ☐ Classify every cloud service in scope by capability type: application, platform, or infrastructure
- ☐ Map shared responsibility boundaries for each capability type and each service
- ☐ Identify all APIs in scope (CSP management APIs, application APIs, internal service APIs)
- ☐ Verify that all CSP audit reports (SOC 2, ISO 27001) are current and that scope covers services in use
- ☐ Confirm that all cloud service partners have current audit coverage or are subject to compensating vendor assessments
- ☐ Document any capability types or services that fall outside provider audit coverage as residual risks

How to use this: *This checklist should be completed and signed off before any technical testing begins. Items marked as residual risks should be escalated to the engagement sponsor for formal acceptance or remediation planning.*

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud security practitioner is assessing a financial services organisation that uses a cloud service broker to manage identity and access across three cloud providers. The broker holds no independent audit

certification. Which aspect of the cloud reference architecture most directly identifies this as a security governance gap?

- A) A. The cloud service user role, because the organisation is responsible for selecting appropriately certified providers
- B) B. The cloud service partner role, which requires that brokers with privileged access to customer environments hold equivalent audit assurance to primary CSPs
- C) C. The infrastructure capability type, because identity management is always classified as an infrastructure concern
- D) D. The regulator role, because compliance frameworks require certification of all participants in a cloud environment

Answer: B. The cloud service partner role, which requires that brokers with privileged access to customer environments hold equivalent audit assurance to primary CSPs

Q2. Which statement best describes the distinction between cloud computing activities and cloud service capabilities in the reference architecture?

- A) A. Activities describe the technical functions a cloud service delivers; capabilities describe the actions performed by cloud participants
- B) B. Activities and capabilities are interchangeable terms describing the same architectural concept from different perspectives
- C) C. Activities describe the actions and responsibilities of participants in a cloud environment; capabilities describe the technical functions that cloud services provide
- D) D. Activities refer only to the cloud service provider's operational responsibilities; capabilities refer only to the cloud service user's consumption patterns

Answer: C. Activities describe the actions and responsibilities of participants in a cloud environment; capabilities describe the technical functions that cloud services provide

Q3. An organisation receives a SOC 2 Type II report from its cloud provider covering infrastructure and compute services. The organisation also uses the provider's new serverless platform service, which was launched after the audit period ended. What is the correct security governance response?

- A) A. Accept the SOC 2 report as providing assurance for all services from the provider, including the serverless service
- B) B. Request a new SOC 2 report immediately and suspend use of the serverless service until the new report is received
- C) C. Document the serverless service as outside the current audit scope, identify it as a residual risk, and seek supplementary assurance or implement compensating controls
- D) D. Classify the serverless service as a platform capability type, which is automatically exempt from SOC 2 assurance requirements

Answer: C. Document the serverless service as outside the current audit scope, identify it as a residual risk, and seek supplementary assurance or implement compensating controls

Q4. In the cloud reference architecture, which of the following best describes the security significance of APIs?

- A) A. APIs are relevant only at the application capability layer and do not apply to infrastructure or platform services
- B) B. APIs represent the defined interfaces between architectural layers and are a cross-cutting security concern requiring authentication, authorisation, encryption, and logging at every layer

- C) C. APIs are managed exclusively by the cloud service provider and are not within the customer's security responsibility regardless of service category
- D) D. APIs are relevant only when a cloud service broker is involved in the architecture

Answer: B. APIs represent the defined interfaces between architectural layers and are a cross-cutting security concern requiring authentication, authorisation, encryption, and logging at every layer

Q5. A cloud security practitioner is assessing a new cloud deployment and wants to apply the reference architecture systematically. What should be the practitioner's first action?

- A) A. Run a vulnerability scan of the cloud environment to identify technical risks before establishing the architectural context
- B) B. Request and review all available compliance certifications from the cloud service provider
- C) C. Map the cloud activity roles present in the environment — user, provider, partner, and regulator — to establish accountability boundaries before beginning technical assessment
- D) D. Classify all data in the environment by sensitivity level to determine which regulatory requirements apply

Answer: C. Map the cloud activity roles present in the environment — user, provider, partner, and regulator — to establish accountability boundaries before beginning technical assessment

Reflection Questions

1. Think about a cloud environment you are familiar with, either from work or from study. Can you identify the cloud service users, the CSP, and any cloud service partners involved? Who are the regulators?
2. What capability types are in use in that environment — application, platform, or infrastructure? Does the security control approach in use reflect those capability types, or is a single security model being applied across all of them?
3. Have you ever encountered an assumption that a cloud provider's security extended further than it actually did? What was the consequence, and how might the reference architecture have surfaced that gap earlier?
4. How would you explain the difference between cloud computing activities and cloud service capabilities to a business stakeholder who needs to understand why the shared responsibility model matters to their organisation?
5. If you were assessing a cloud environment that included a broker, what specific questions would you add to your assessment checklist that you would not ask in a direct CSP relationship?
6. The reference architecture was described as the grammar of cloud security conversations. In what ways has mastering shared vocabulary changed how you are able to participate in technical or governance discussions?

Key Takeaways

- The cloud reference architecture is a NIST, CSA, and ISO framework that describes the roles, activities, and capability types present in any cloud environment — it applies universally regardless of provider.
- The four cloud computing activity roles are cloud service user, cloud service provider, cloud service partner (including brokers and auditors), and regulator — each with distinct accountability implications.
- The three cloud service capability types — application, platform, and infrastructure — map directly to SaaS, PaaS, and IaaS and determine the shared responsibility boundary for security controls.

- APIs are the defined interfaces between every layer of the cloud architecture and are a cross-cutting security concern requiring authentication, authorisation, encryption, and logging at every layer.
- Cloud service brokers concentrate trust across multiple environments and must be assessed with the same rigour as primary CSPs, including review of their own audit coverage and subprocessor relationships.
- Cloud service auditor reports (SOC 2, ISO 27001) provide independent assurance but have defined scopes — practitioners must verify that the specific services in use fall within the audit scope before relying on these reports.
- The reference architecture is the first analytical tool to apply in any cloud security engagement, mapping roles and capability types before beginning technical testing.
- Conflating cloud computing activities (accountability) with cloud service capabilities (technical function) produces incomplete assessments — both dimensions must be maintained separately and assessed explicitly.

Recommended Next Actions

Put this lecture to work within the next seven days:

7. Download and review NIST SP 500-292 (NIST Cloud Computing Reference Architecture) — read the section on cloud actor roles and identify how each role maps to an organisation you are familiar with.
8. For any cloud environment you currently use or assess, create a simple four-column table listing every service, its capability type, the party responsible for each security control layer, and the audit coverage available — present this to your team as a shared responsibility map.
9. Review the scope section of the most recent SOC 2 Type II report from a cloud provider you use and verify that every service your organisation uses is listed within the audit scope. Document any out-of-scope services as residual risks.
10. Apply the OWASP API Security Top 10 checklist to any API you own or consume and identify which of the ten vulnerability categories are currently not addressed by existing controls.